June 16, 2025

Centers for Medicare & Medicaid Services
Department of Health and Human Services
Attention: CMS-1833-P, Mail Stop C4-26-05, 7500 Security Boulevard
Baltimore, MD 21244-1850.

Submitted electronically via: federalregister.gov

Subject: Request for Information: Health Technology Ecosystem

Relevant Background

DirectTrust® is a non-profit, vendor-neutral, 501(c)(6) alliance of more than 100 member organizations dedicated to establishing trust in a connected world. We began as an initiative of the Office of the National Coordinator (ONC), now Assistant Secretary for Technology Policy, in 2009 to advance secure, trusted, and identity-verified communication for healthcare. The ONC spun us off as a self-sufficient trust framework and private organization to continue the work in 2012. Since that time, more than 6.5 billion Direct Secure Messages have been exchanged through the network we oversee, and the number continues to grow.

DirectTrust serves multiple roles to promote interoperability and interconnectivity for health and related services. We develop consensus-driven community-focused standards for healthcare communication. We are an American National Standards Institute (ANSI) standards development organization and accreditation and certification body governed by the Electronic Healthcare Network Accreditation Commission (EHNAC). We steward trust frameworks and supportive services, including our national provider Directory, secure information exchange like Direct Secure Messaging, and other identity-verified credentials; additionally, we support a community of Certificate Authorities that issue certificates for use in a variety of healthcare use cases including for implementers of the HL7® UDAP FAST Security for Scalable Registration, Authentication, and Authorization IG, as required in Facilitated FHIR® under TEFCA.

DirectTrust is committed to fostering widespread public confidence and trust in health technology, including in the interoperable exchange of health information, while also promoting quality service, innovation, cooperation, and open competition in healthcare.

General Comments

Following the General Comments, we address specific sections and questions.

Digital Identity

Common to all stakeholder groups is the need for establishing reliable and trustworthy digital identity credentials to support health information sharing, positive identity within the information

Copyright 2025 by DirectTrust, All Rights Reserved | 1629 K Street NW, Suite 300 | Washington, DC 20006 | DirectTrust.org

that is exchanged, and supporting rights to have access to electronic health information (EHI). We believe that a standards-based digital identity follows the individual for all the roles an individual may play in the exchange of EHI and in interactions with the health system. We believe this should be based on IAL2/AAL2 approaches to identity proofing and authentication. The digital identity of an individual should be common and shared in as broad a context as possible to reduce reliance on proprietary means of digital identity and authentication. Where that may not be possible, we believe there should be acceptance of standards-based digital identities that adhere to an equivalent level of trust based on par level approaches to identity proofing, digital identity credential issuance and management, and authentication. Digital identity is explicitly mentioned in B.3.PC-14, C.3.PR-9-10, D. PA-3-4, 2.TD-3, F.3.VB-14.

Patient Matching and Identity Resolution

Though explicitly only mentioned in F.1.VB-3, we believe patient/person matching is essential to address stakeholder interests of providers, payers, patients/caregivers, and value-based care organizations. We advocate for the establishment of a common set of patient demographic and identity information that will be expected both as an outcome of identity proofing and issuance of patient/caregiver digital identity credentials but also that is in common with patient matching requirements. This can assure that the subject of EHI is accurate when it comes to patient record location for health information exchange, extending into the workflow of EHRs/HIT for the purpose of incorporation and reconciliation of received EHI. This should be true also for supporting downstream workflows where patient identity is significant to successful outcomes such as for supporting check-in processes and self-directed appointment scheduling, consumer facing API access to interact with EHI, and other similar purposes. The DirectTrust Privacy Enhancing Record Locator Service (PEHRLS) Consensus Body is dedicated to supporting this work. Our commitment is further demonstrated by our participation with the Patient ID Now Coalition[1] and endorsement of the Patient Matching And Transparency in Certified Health IT Act of 2025 (MATCH IT Act)[2].

FHIR

For the sake of health information exchange between providers, payers, patients/caregivers, and value-based care organizations, we urge the use of facilitated FHIR supported by a technical trust framework chained to a common root of trust. We believe that this would be vitally useful to TEFCA and other health information exchanges, as the use of FHIR allows for implementation of interoperability at scale, as recommended by the ONC FHIR At Scale Taskforce. FHIR is explicitly mentioned in C.2.PR-5, C.2.PR-8, C.2.PR-10, D.PA-4E, E.3.TD-5, E.4.TD-14-15 E.4.TD-14, F.3.VB-15.

[1] https://patientidnow.org/

[2] https://www.congress.gov/bill/119th-congress/house-bill/2002

TEFCA & National Networks

We believe that TEFCA can play a useful role that complements but does not duplicate or drive out of use current forms of health information exchange that serve legitimate and established purposes for providers, payers, patients/caregivers, and other stakeholders. We recommend that CMS and ASTP/ONC consider how TEFCA can be positioned to complement useful current functioning exchanges and not be redundant to their exchange purposes.

We also believe that TEFCA needs to support "push" based exchange modalities in addition to the widely adopted "pull" communication available in the network today, and should do so by allowing and encouraging Direct Secure Messaging, the existing ubiquitously available mechanism in use in the market.

We propose that the Common Agreement, or the QHIN Technical Framework allow Direct Secure Messaging as a parallel path for push-based exchange in much the same way as the eHealth Exchange DURSA and the Carequality Connected Agreement make this allowance explicitly for electronic case reporting (eCR).

Direct Secure Messaging is widely adopted among certified EHR platforms and beyond for use cases that are required by certification, as well as for a great many novel and creative use cases that fall outside of those requirements. DirectTrust is the single on-ramp to Direct Secure Messaging, just as TEFCA was created as a single on-ramp for query-based exchange. Today, TEFCA encompasses push-based messaging in a very limited capacity and excludes Direct for QHIN-to-QHIN exchanges. The majority of QHINs, participants and subparticipants have shown interest in using the ubiquitously adopted mechanism of Direct Secure Messaging for push-based communications, not XCDR. Allowing or encouraging Direct under TEFCA is the efficient, cost effective and easiest way to streamline all types of exchange processes (Direct, Query, FHIR) necessary for interoperable data exchange in the US healthcare system. This will also bring the billion push messages that are exchanged in the DirectTrust network under the TEFCA umbrella. This can be done with modification to the Common Agreement and/or TEFCA's QHIN Technical Framework (QTF).

Electronic Case Reporting (eCR) predominantly occurs via Direct Secure Messaging with more than half of all eCR traffic transmitted via Direct. If Direct is not included under TEFCA, current proposals (including FY 2026 IPPS) to incentivize organizations to submit eCR via TEFCA will create additional spending and waste, while organizations build or re-architect their technology to replace Direct. There is no additional benefit of communicating eCR via XCDR. If Direct were allowed and encouraged or recognized as part of TEFCA, including communicating eCR, it would move organizations towards TEFCA, leveraging the technology they already have. This would result in more data exchanged and more eCRs submitted via entities that are already using Direct, with better security while avoiding wasteful spending.
TEFCA is explicitly addressed at B.2.PC-10-11, C.2.PR-6, C.3.PR-11, D.PA-1, E.3.TD-6, E.4.TD-14.

Directory

We urge the establishment of common provider directories that can enable common sources of digital identity and address information useful to support health information exchange, enable understanding of provider digital identity information, and support downstream use of directory information for consumer and stakeholder engagement with providers. We also believe that identity assurance can play a substantial role in improving the quality of directory entries.

Without directories, interoperability will not work. Stakeholders must be able to confidently locate endpoints for the information to flow. DirectTrust's Aggregated Directory is heavily relied upon for Direct Secure Messaging and just completed a multi-year technology re-architecture (including the deployment of an API) and policy update process. Our Directory is the first to comply with the HL7 National Directory Standard and can now collaborate with directories of outside entities (such as CMS). A public-private partnership between DirectTrust (Aggregated Directory), HL7 (National Directory standard), The Sequoia Project/RCE (TEFCA/FHIR Directory), and CMS would dramatically advance interoperable exchange.

Directory is explicitly addressed in C.2.PR-10, D.PA-4, E.3.TD-5, F.3.VB-15.

Direct Secure Messaging Explained

Direct Secure Messaging is interoperable push-based communication using the Direct Standard®. It is point-to-point data sharing, analogous to secure email, but with additional security features that support confidential exchange of health information. All certified EHRs must meet the Direct Standard® and are capable of Direct Secure Messaging. The current established use cases for Direct Secure Messaging include Referrals, Continuity of Care, Notifications (like Admit/Discharge/Transfer), Electronic Case Reporting (half of eCR happens today via Direct), 360x Closed-Loop Referrals, and EMS Transfer. Direct Secure Messaging has successfully scaled because it uses Public Key Infrastructure (PKI) to ensure that messages are encrypted, authenticated, and secure. This infrastructure, combined with DirectTrust's trust framework, accreditation, policies and governance, allows healthcare organizations to exchange sensitive information confidently across the broad, interoperable network governed by DirectTrust.

Direct Scales Because of Digital Certificates and Identity-Verification

Direct addresses are identity-verified and tied to a digital certificate that assures identity. Direct Secure Messaging can guarantee messages will reach intended recipients because Direct uses identity-proofed addresses that are frequently tied to individuals or teams. Direct also provides Message Delivery Notifications (MDNs) that confirm receipt. By comparison, XCDR, currently the QHIN-to-QHIN push exchange standard under TEFCA, uses organizations' general endpoints that provide no guarantee that messages will reach the specific intended recipient. Because of DirectTrust's success of achieving technical trust at scale, DirectTrust also provides the technical trust foundation for other exchange modalities (view explainer video), including

Carequality and eHealth Exchange for query-based exchange since 2020 and TEFCA QHINs for Facilitated FHIR since 2024.

Direct by the Numbers

- DirectTrust is the only national network and at-scale modality for secure push-based interoperability.
- More than 6.5 billion Direct Secure Messages have been exchanged to date.
- More than 200,000 organizations have access to Direct Secure Messaging.
- Nearly 3 million trusted DirectTrust addresses exist, with over 1 million of those published in an Aggregated Directory.

While Direct Secure Messaging is not explicitly referenced in the RFI, it is relevant in multiple contexts, including wherever "existing exchange" is discussed, such as B.2.PC-10-11, C.1.PR-3.

Specific Comments

B. Patients and Caregivers

2. Data Access and Integration

PC-12 - What are the most valuable operational health data use cases for patients and caregivers that, if addressed, would create more efficient care navigation or eliminate barriers to competition among providers or both?

b. What use cases are possible today?

The most significant operational use cases for patients today that would serve to create more efficient care navigation or eliminate barriers to competition among providers include many that can be effectively enabled via Direct Secure Messaging:

- Closed loop referrals between primary care providers and specialists that include support for appointment scheduling, order management, clinical results or reports of specialist services, and sharing of clinical information to support all of these requirements in an interoperable way
- Shared care planning, care management, and care coordination amongst providers involved in a patient's care so that it occurs in a person centered manner and not just as a matter of what happens within an encounter or visit to a given care setting - especially where the patient is being treated for a condition that requires longitudinal, episode based care. This should be true not only in value-based care arrangements but in any such circumstance such as for chronic disease management

- Electronic notification of significant events in the course of care much as is required for certain ADT events by CMS regulations for hospital visits to a patient's primary care physician and other care team members

c. What should be possible in the near future?

- Better support for a patient to be able to consolidate their electronic health information from multiple provider sources without the patient or their caregiver bearing the burden of having to "pull" the information from those sources but to have the information triggered to be forwarded as a matter of custom based on significant events such as discharge or departure.
- Access to provider directory information including provider digital contact information, and information supportive to patient or caregiver self-service for appointment scheduling
- Access to pricing and out of pocket cost information that build on pricing and cost transparency regulatory requirements to support patients being able to understand costs of their services, out of pocket responsibilities and availability of payment methods that may work to support their ability to pay.
- Make it possible for a consumer to use a digital identity to communicate verified attributes to the EHR to update their EHR demographics
- Allow for patients to use electronic means to communicate their verified demographics information and insurance card information to the EHR.

d. What would be valuable but may be very hard to achieve?

To address adoption challenges, ensuring the trustworthiness of consumer facing health applications particularly for the privacy and security of electronic health information (EHI) accessed, processed, stored, and disclosed by them is paramount. Aside from the narrow bandwidth of regulatory oversight by the Federal Trade Commission in accordance with federal breach notification requirements that involve EHI maintained by consumer health applications, there is no significant federal regulation of the consumer health space when it comes to security and privacy of the EHI. However, we encourage CMS, ASTP/ONC, and the Office for Civil Rights (and any successor form of office responsible for enforcement) to support efforts such as the CARIN Alliance Code of Conduct to serve as best practice for the assurance of the security and privacy of EHI maintained by consumer health applications. DirectTrust maintains an independent certification for the CARIN Code of Conduct.

3. Information Blocking and Digital Identity

PC-14 - Regarding digital identity credentials (for example, CLEAR, Login.gov, ID.me, other NIST 800-63-3 IAL2/AAL2 credentialing service providers (CSP)):

a. What are the challenges today in getting patients/caregivers to sign up and use digital identity credentials?

Many consumers are accustomed to using digital identity credentials for many use cases ranging from interaction with government websites such as the IRS or to qualify for expedited travel access through airport security using TSA PreCheck with CLEAR. While the process to receive such a credential isn't usually that difficult, the IAL2 identity proofing exercise is a barrier for some people that don't have appropriate identity evidence. Even at its best, it is enough work for the user that they would prefer not to have to do it over and over again as they do today, and from a societal point of view, the identity proofing event is the most expensive part of credential issuance, frequently requiring a face-to-face in person or video encounter when technology mechanisms to match the person to their identity evidence fail. If a digital credential could work in all the healthcare contexts and user experiences, savings accrue both to the consumer and the ecosystem. There are multiple challenges to the use of a single credential to access multiple digital assets. The first expectation is that all digital endpoints accept digital credentials and have the services of an identity provider (IdP) to evaluate them or have this capability on their own. This we might call ubiquity. Next, as long as there are more than one or two IdPs in the market, each IdP will need to know how to accept the other IdP's credentials - reciprocity. This is two issues - one is the technical ability to accept another's credential, and the other is that IdPs' business models assume their services will be marketed to every "relying party" or data source. The economic model needs to expect that IdPs won't charge each other, but will instead provide services both for identity assurance and credential issuance as well as for evaluating credentials from other IdPs. Also, if we expect that such credentials are going to be used by legions of consumers, more than a few IdPs will be required to support the demand. This is not impossible, but will need collaboration between the current players and a trust framework to support the expectations.

A trust framework will be important to satisfy other policy expectations as well. DirectTrust is such a trust framework.

If multiple IdPs are involved in exchange, relying parties will want to know that one credential is as good as another, and IdPs will want to know that the process for validating credentials is universally accepted. This requires certification or accreditation of the IdPs

and demonstration of conformance to a common policy framework. DirectTrust and Kantara collaborated on a model for such a framework of frameworks with the CARIN Alliance convening the discussion. The CARIN Credential Policy is very close to complete, and DirectTrust has built our Registration Authority (RA)and our IdP program in conformance with it. Future work will be required to ensure that digital credentials issued by states like mobile driver's licenses (mDL) can be accepted and validated under the policy as well.

Another related topic that must be addressed is the registration of the requesting application at the data holder server, and the authentication and reauthentication (on subsequent visits) of the user. This can be automated by utilizing standards that support dynamic registration and authentication which have been stipulated by the RCE for use in TEFCA. More on this below.

Assuming portability/reciprocity, policy equivalence, and authentication, we need to determine how identity resolution will work. In healthcare, identity resolution is referred to as patient matching. Patient matching compares the identity attributes (first, last, gender, date of birth, address and others) between systems. When an application is using a digital credential to login to a data holder, the verified attributes collected in the identity proofing process are securely passed in assertions to the data holder. The data holder uses these to find a patient record within their system that matches the attributes according to algorithms set by the data holder or the trust community. This is one of the most vexing challenges we need to address. Because current processes don't use verified attributes or reliable identifiers, false negatives (not finding records that are there) are the norm and false positives (mis-matching records) still occur.

Another issue is that IdPs have a "minimum necessary" standard - they prefer not to retain extra attributes about a person to reduce liability. Trust communities may suggest additional attributes be captured like email address, cell phone number or the last 4 numbers of a social security number, but IdPs don't capture those attributes by default. While the data holders may have the ability to capture those attributes, each encounter might have different attributes available. And four of five of the basic attributes are changeable - only date of birth remains constant regardless. Lots of good work has been done on patient matching in the FAST Identity Initiative, but their focus has been business to business matching mostly which is grappling with high false negatives. It is the FAST Security IG that stipulates the dynamic registration and authentication of client apps.

The goal: With an IAL2 credential, a patient should be able to get access to all their records from multiple sources using a single application or service.

The challenge: Data holders and their business associates (EHR companies) don't trust that identity resolution (patient matching) will work reliably enough to allow access using IAL2 credentials. A quote: "At the scale of millions, there will be errors, who's liable for these?" – an EHR company representative.

The barrier/root cause: While getting an IAL2 credential ensures that verified attributes can be included in queries for data on the network, these attributes are not collected as part of the intake/check-in process at the health system.

Solution: Add accepting/collecting verified attributes from IAL2 identity assurance processes as part of the CEHRT (Certified EHR Technology) requirements. In other words, require intake to collect the same verified attributes that will be shared in queries for data. **Plus:** As part of the intake process, digitally share the payer patient identifier as an additional attribute. **Also**, require such identifiers to be "portable" - in other words, require payers to utilize the same individual identifiers when patients change payers in much the same way as an individual can keep a mobile number when they change carriers.

Networks also need to continue to strengthen matching requirements based upon prior names and addresses in addition to current demographics.

Caregivers represent a unique challenge that has not yet been dealt with in the identity community broadly.

The Goal: Enable caregivers to use their own digital credentials to access patient records securely. The patient (grantor) must be able to revoke access at any time.

The Challenge: There isn't currently a way to establish the relationship that can be communicated across the wire to the data holder so that one person can access records for another.

A Proposed Solution: A remote online notary that is accredited as Registration Authority/IdP in a trust framework can issue a special credential with two sets of verified attributes and metadata about the relationship including an expiration date. All of the information is digitally signed and communicated in assertions to the data holder. The caregiver's attributes will be used for authentication to the server, but the patients' attributes will be used for identifying the correct patient at the data holder. The data holder will validate that the caregiver's authorization is still valid and unexpired in the same way they validate any credential for authentication.

DirectTrust has been collaborating with the Remote Online Notary Association and some of their members to establish an approach to solve this problem. Notaries are experienced

in identity verification and documenting relationships. RON services operate 24/7, supporting fraud prevention and secure identity proofing as a trusted digital layer.

b. What could be the benefits to patients/caregivers if digital identity credentials were more widely used?

As noted in the previous response, consumers are reasonably experienced with the use of digital identity credentials for both healthcare and non-healthcare uses. If those credentials were able to be reused or supported across disparate healthcare websites, portals, and apps as we have described, we have the potential to address the "portalitis" affliction described often by patients. If digital identity credentials were portable, reciprocal, reusable, and supported by the wide variety of accesses patients and caregivers need, the burden of patient access to records could be substantially reduced. Further, an established set of identity credentials could also reliably supply demographic information and context to support consumer-facing workflows to populate identity information useful to completing pre-service forms, to make scheduling and appointment requests, to support patient matching needs in requesting records in a business to business context, and other purposes.

c. What are the potential downsides?

With consumer use, there is the risk that the individual's digital identity may be shared between patient and caregiver, or between the patient and family members which may make identity uncertain when consumer facing websites and apps are accessed. This may be a matter of consumer choice and necessary if we don't solve the communication of the caregiver relationship effectively. It could be mitigated with multi-factor authentication mechanisms that include biometrics that reliably bind attributes to the individual.

There is always the risk that if digital identity credentials are compromised or stolen, the potential for breach of a person's electronic personal health information (ePHI) or for impersonation of the patient for the purpose of accessing there is heightened and broadened. We can mitigate this with appropriate requirements for multi-factor authentication, but cannot eliminate the possibility of such an outcome.

d. How would encouraging the use of CSPs improve access to health information?

The use of CSPs/IdPs and remote online notaries could help standardize processes for identity proofing of patients and caregivers, especially by permitting remote processes to be used to avoid the burden of necessarily presenting in-person. This also would be useful

for supporting standards-based methods for issuing digital credentials compliant to industry and federally recognized standards.

e. What role should CMS/payers, providers, and app developers have in driving adoption?

CMS could recognize in coordination with ASTP/ONC appropriate standards to be used and lead the way by adopting requirements for the use of such standards to access CMS websites intended to be used by beneficiaries. These can be the same as used by consumers in accessing IRS, Social Security, and other federal websites that follow similar identity authentication processes enabled by the federal government for public use. If we establish reciprocity, these credentials can be used in commercial healthcare contexts as well. ASTP/ONC already has certification requirements for the use of OpenID Connect across its API requirements for patient and provider facing use, and CMS requires its use in access to payer held electronic health information (EHI) in its regulatory requirements for payer interoperability under CMS-0057-F and CMS-9915-F. Building on these requirements, CMS and ASTP/ONC can further enhance requirements for the use of digital identity credentials in federal requirements for the use of HIT. The HHS Office for Civil Rights (OCR) also recently proposed the use of multi-factor authentication (MFA) in its recently proposed HIPAA Security Rule. While OCR did not include patients and caregivers in the requirement, OCR could provide guidance for adoption of digital identity credentials that could also apply to consumer facing access.

Payers, providers, and app developers could play strong contributing roles by supporting the use of portable, reusable digital identity credentials that abide by federally recognized standards that follow the individual. App developers and HIT developers could move away from proprietary schemes or the use of IdPs that do not support the use of digital identity for consumer access beyond the boundaries of their own products. Providers and payers could support the issuance of digital identity credentials or work to sponsor or recommend the use of CSPs to issue them like how such credentials are given to individual practitioners and clinicians for purpose of use in healthcare workflows like electronic prescribing. These steps support the move to the use of interoperable and reusable digital identity credentials issued by independent CSPs that service the market, which could be based on federally recognized standards and methods.

f. How can CMS encourage patients to get digital identity credentials?

It is doubtful that CMS can require the use of digital identity credentials for patients as a matter of regulation, especially assuming no national patient identifier. However, CMS may consider making available voluntary beneficiary registration for their issuance at key

intervals such as when beneficiaries are newly enrolled for Medicare benefits or at intake in a Medicare benefit or insurance program. CMS might make it a contractual requirement or requirement for the use of federal funds for Medicaid and CHIP plans to make similar voluntary beneficiary registration for digital identity credentials available. CMS could also work with ASTP/ONC and HHS OCR to provide guidance materials to the public on the benefits of the use of digital identity credentials for consumers, and to make the capabilities needed for their issuance and interoperability a matter of requirement for HIT certification for consumer facing portals and FHIR APIs.

C. Providers

2. Data Exchange

PR-5. Which of the following FHIR APIs and capabilities do you already support or utilize in your provider organization's systems, directly or through an intermediary? For each, describe the transaction model, use case, whether you use individual queries or bulk transactions, and any constraints:

- ***Patient Access API***
- ***Standardized API for Patient and Population Services***
- ***Provider Directory API***
- ***Provider Access API***
- ***Payer-to-Payer API***
- ***Prior Authorization API***
- ***Bulk FHIR – Do you support Group ID-based access filtering for population-specific queries?***
- ***SMART on FHIR – Do you support both EHR-launched and standalone app access? What does the process for application deployment entail?***
- ***CDS Hooks (for clinical decision support integrations)***

DirectTrust is not a provider organization nor a data holder, and so we will not comment on the use of the listed API capabilities, however, our organization supports the use of facilitated FHIR API based exchange under TEFCA by operating a technical trust framework with multiple competitive players offering digital certificates that chain to our hosted root of trust. All of these transactions can benefit from this infrastructure by providing organizational identity assurance for exchange participants and providing assurance on each facilitated FHIR API transaction of TEFCA participation.

DirectTrust also hosts a provider directory for our community which was recently updated to support the National Provider Directory API standard allowing our community to use

the API as an alternative access method to our Directory. Today, our directory contains only Direct Secure Messaging endpoints (Direct Addresses) but has been updated so that other endpoint types including FHIR endpoint URLs and home community IDs can be associated with the same organizations that deploy Direct.

PR-6. Is TEFCA currently helping to advance provider access to health information?

a. Please provide specific examples

TEFCA has the potential to broaden the basis of health information available for query based "pull" of health information on a national basis. Where national networks were unable to connect to the large number of small EHRs, long term post-acute players and rural locations where data has been more difficult to access to date, TEFCA may have benefit. The exchange of health information for treatment was widely available on a national and regional basis before through existing national networks and through local, community, regional, or state based HIEs, and point to point exchange. It is difficult to say whether the availability of health information for the benefit of a local provider community has been more than incrementally improved so far with TEFCA participation being strictly optional.

Most TEFCA participants have been participating in analogous query based exchange as Carequality Implementers or CommonWell Service Adopters. Even for Individual Access Services (IAS), the existing networks were providing IAS services already, though neither TEFCA QHINs nor the other national networks have many data holders that are responding to IAS requests. As TEFCA continues to roll out it will need to continue to address the concerns data holders have about requests for data under the guise of the treatment purpose of use which are actually for other purposes, much which may be valid, but for which there is no current guidance or guardrails.

For push-based exchange like for referrals, Direct Secure Messaging within the DirectTrust network is already in place making the TEFCA message delivery modality using the IHE profile XCDR superfluous. Currently use of XCDR is extremely limited under TEFCA and is not currently targeted for use by most of the QHINs for messaging participants and subparticipants.

b. What changes would you suggest?

We propose that the Common Agreement, or the QHIN Technical Framework allow Direct Secure Messaging as a parallel path for push-based exchange in much the same

way as the eHealth Exchange DURSA and the Carequality Connected Agreement make this allowance explicitly for electronic case reporting (eCR). This would have the impact of reducing overall cost and demonstrating TEFCA adoption by incorporating Direct Secure Messaging scale as a part of TEFCA exchange.

Some healthcare organizations may be considering utilizing TEFCA, but may already be participating in regional or state based HIEs, Direct Secure Messaging or point to point exchange for data submission or bi-directional information sharing (such as for immunization information) with providers. For example, Electronic Case Reporting (eCR) has grown significantly outside of TEFCA and offers a tremendous amount of value to providers and public health entities alike. eCR automates the secure submission of reportable disease cases from healthcare providers' electronic health records (EHRs) to public health agencies through the AIMS platform hosted by the Association of Public Health Laboratories (APHL). While there are multiple pathways for submitting eCR, Direct Secure Messaging is the most widely used pathway for eCR today, supporting half of all eCR traffic across the United States and we have observed that this continues to grow. Many EHRs only have the capability to submit eCR today via Direct Secure Messaging since Direct is secure, standards-based, and interoperable with all certified EHR systems already. We encourage CMS to continue to maintain the existing pathways for submitting eCR, including Direct Secure Messaging. In the 2026 Inpatient Prospective Payment System (IPPS) proposed rule, regarding the eCR measure for the Public Health Reporting Objective for Promoting Interoperability, CMS suggests that eCR communication should utilize methods supported by governance and technical frameworks. Direct Secure Messaging meets both of those criteria since the operators of the DirectTrust network are accredited by our organization, governed by our policies, and their adherence to standards is ensured through CEHRT certification. If the goal is to avoid singular connections and instead rely on proven networks, Direct Secure Messaging for public health reporting can also support this intent. Instead of limiting public health reporting to TEFCA, we encourage CMS to support the use of proven existing parallel paths. This allows the entities to use what's working and not require them to unnecessarily build something new.

The use of TEFCA for other exchange purposes, and exchange modalities beyond HL7 v3 C-CDA based document exchange has been very limited to date. In order for TEFCA to improve its applicability to other as yet "unpaved" paths for payment and operations, it should be open to allowing under the Common Agreement modalities beyond the IHE profiles and FHIR that have been the requirements to date.
For payment the market is already required to use ANSI X-12 implementation specifications for the exchange of the HIPAA standard transactions, and so the use of TEFCA for this purpose of use does not provide incremental utility and requires

substantial rework and new development and deployment at considerable cost for all connected stakeholders. Some payment sub-purposes of use such as the sharing of healthcare attachments, sharing pricing information including negotiated rates for purpose of provision of good faith estimates, or sharing health information for payer audit purposes or utilization review there is not yet an established HIPAA standard transaction. These may make sense as FHIR specifications, but other challenges remain for these new transactions. For example, many organizations maintain different systems for revenue cycle and clinical applications and as a consequence may not have all the necessary information in one system to fulfill some of these new transactions. While TEFCA's goal of a single on-ramp is worthy, the cost of rework and redeployment will likely exceed the savings of eliminating existing connections and intermediaries.

Participation of actors with non-treatment purposes also may have been discouraged by a governance process that has limited participation in discussions to those committed to participation in TEFCA including only QHINs and their participants and subparticipants. This may have inhibited innovative approaches which might be considered for use in TEFCA by making these difficult to discuss and deploy.

Currently, TEFCA still requires participation in only one QHIN at a time which continues to raise the question of what becomes of existing participation in other health information exchanges that support other permitted purposes of exchange. CIOs and provider HIT leadership may be left to question the value of TEFCA beyond its current functions when it comes to these kinds of questions.

c. What are other options outside of TEFCA?

See prior comments under PR-6 b above. We propose that the Common Agreement, or the QHIN Technical Framework allow Direct Secure Messaging as a parallel path for push-based exchange in much the same way as the eHealth Exchange DURSA and the Carequality Connected Agreement make this allowance explicitly for electronic case reporting (eCR). This would have the impact of reducing overall cost and demonstrating TEFCA adoption by incorporating Direct Secure Messaging scale as a part of TEFCA exchange.

d. Are there redundant standards, protocols or channels, or both that should be considered?

See prior comments under PR-6 b above. Promoting XCDR as the mechanism for push between QHINs has caused confusion in the market and interest in using this modality is low.

Copyright 2025 by DirectTrust, All Rights Reserved | 1629 K Street NW, Suite 300 | Washington, DC 20006 | DirectTrust.org |

PR-7. What strategies can CMS implement to support providers in making high-quality, timely, and comprehensive healthcare data available for interoperability in the digital product ecosystem? How can the burden of increasing data availability and sharing be mitigated for providers? Are there ways that workflows or metrics that providers are already motivated to optimize for that could be reused for, or combined with, efforts needed to support interoperability?

Overview - Current State

The digital product ecosystem is not fully enabled by the currently required USCDI framework in the way some companies would prefer. The APIs and the transactions which are currently supported by what is required under regulation is limited to accessing/querying for mostly clinical information. Through the end of the year, USCDI V1 is required under TEFCA exchange, but in January 2026 v3 will be required introducing new data classes and expanding elements within them, but for the most part still representing only clinical information. For some application developers, this data will be extremely valuable, others will desire more.

For those companies that are looking to allow patients to aggregate their data and share it with others for a variety of purposes with the patient's consent, much can be accomplished at current course and speed if we successfully solve the digital identity problem discussed above.

Also important is establishing a mechanism for ensuring organizational identity in the ecosystem and providing mechanisms for applications to make new connections to endpoints without manual orchestration. The FAST Security accelerator has an Implementation Guide called *Security for Scalable Registration, Authentication, and Authorization (SSRAA)* that utilizes Open ID Connect, OAuth 2, PKI and the Unified Data Access Profiles (UDAP) to support business-to-business transactions like those contemplated for Facilitated FHIR in TEFCA. Further strengthening this model, DirectTrust has subcontracted with Recognized Coordinating Entity (RCE) of TEFCA to deploy a technical trust mechanism for certificates to be issued from a trusted "root". This mechanism has the potential to provide flexible support for the ongoing security needs of TEFCA and perhaps other initiatives.

Using What We Have

CMS should also leverage current means of health information exchange that are already in use, especially as supported by certification standards with ASTP/ONC's certification program that promote secure trusted exchange. Direct Secure Messaging has long been a part of the capabilities of Certified EHR Technology (CEHRT). This "push" mechanism for exchange has proven to be a highly adaptable and usable standard across not only

hospitals and clinician practices, but also with exchange partners who have not benefited from an EHR incentive program to spur adoption of EHR technology. Direct Secure Messaging can be incorporated into EHRs or technology platforms but can also be separately accessed for use via a web browser. This allows for interoperability and data exchange for resource constrained organizations such as FQHCs, RHCs, rural emergency hospitals, community based providers, post-acute care providers, child welfare, ambulance, and other types of organizations challenged to participate in other forms of health information exchange. Many commercial companies have used Direct as a mechanism for directing data to EHRs for incorporation under the requirements of regulation.

Reducing Burden

For the question of the burdensome nature of the volume of data received, many vendors are successfully using AI and more prosaic means to deduplicate and organize the data received. The inclusion of provenance in USCDI provides a new means of providing support for algorithms to appropriately organize data aggregated from multiple sources. As this becomes more commonplace, perhaps deduplication and other organizing principles could be included as certification requirements or another regulatory mechanism.

Expanding Scope to Administrative Transactions

Administrative transactions are not supported by USCDI for the most part. While many EHRs support such transactions as registration and scheduling they do so through proprietary APIs which are generally offered at additional cost. The transactions supported by most EHRs for FHIR transactions are query only. The only inbound to EHR requirement in USCDI is "clinical information reconciliation and incorporation" (§ 170.315(b)(2)) which allows for reconciling information which is received via Direct or that was queried from another endpoint. While standards-based specifications for writes to the EHRs are available, both the data holder organization and the EHR company may be reticent to allow external applications to perform writes to their database. There are examples of successful custom applications using proprietary APIs to interact in this way, but these are mostly limited to business associates of the data holder and contractual partnership with the technology company.

The goal of affording the app ecosystem unfettered access to the APIs deployed at the health system suffers from fundamental challenges:

1) Not all EHRs will support the same transactions besides those required under regulation, even through proprietary APIs.

2) The costs to build out APIs for new functions, whether standards-based or proprietary will be expensive for companies that don't currently support them. These costs will need to be recovered, either in higher prices to data holder clients or for fees paid by third party developers. No development is free.
3) In order for an application to receive permission for write access to the data holder, a high degree of trust in the application will be required. Queries for the most part only raise issues of privacy and security, where writes raise cybersecurity and data integrity concerns as well.
4) Writes also ratchet up the identity concerns discussed above. The data holder will want to have very high assurance that the person is who they say they are (identity assured) and that the records they are altering belong to them (resolution) and that if they have an account the person behind the app is the person that opened the account (authentication).
5) If the data holder is in control of all elements of the identity equation, they may partner with a third party to deploy a custom app for a valuable purpose. In order for the data holder to allow an external company this sort of authorization the application developer might need to be subject to substantial independent assessment, testing and certification.

Organizations that operate in the patient-facing application realm have long wanted to be able to offer the incremental transactions of most value to patients - checking your balance, paying your bill, understanding the costs of the procedure you have scheduled, self scheduling and even just updating information necessary for an upcoming encounter.

If such a future is to be achieved, collaborative discussions will need to take place within the industry to determine how trust can be established and how new capabilities would be paid for if they were mandated. Rather than requiring this, it might make more sense to assume that a mix of USCDI, FHIR capabilities which are not mandated, and proprietary APIs can be used together as they are being used today by companies with appropriate contractual relationships. This would include exploring how additional trust assurance for the client application companies and standardized fee structures and requirements for documentation for APIs might be established either voluntarily or with some form of incentive.

3. Digital Identity

PR-9. How might CMS encourage providers to accept digital identity credentials (for example, CLEAR, ID.me, Login.gov) from patients and their partners instead of proprietary logins that need to be tracked for each provider relationship?

CMS and ASTP/ONC have available regulatory levers they can consider using to either drive or incent adoption of standards-based digital identity credentials for patients by providers that are portable and interoperable with other IdPs. The two could coordinate efforts for development of a certification criterion that included requirements for use of standards-based digital identity credentials that then could be adopted as a Privacy and Security criterion. Alternatively, CMS and ASTP/ONC could work to expand patient access certification requirements to include capabilities to support standards-based IAL2 /AAL2 registration and credential provision processes as a part of the granting of a digital identity credential for patient access to EHI. Either of these approaches would in turn be a part of the definition of Certified EHR Technology which is a prerequisite requirement for Promoting Interoperability, Advanced APM status under MACRA for APM participants, and other program requirements. For actual adoption of standards-based digital identity credentials, it may be difficult to mandate patient use, but CMS should consider how a process of offering patients the chance to adopt standards-based digital identity credentials could be implemented as a part of Promoting Interoperability. Whether certification requirements might be adopted as a security certification criterion or as a part of portal and consumer facing API certification requirements, CMS could work with ASTP/ONC, and OCR to provide guidance on how to educate and encourage adoption of the credentials by patients as was done initially for the adoption of patient portals. An approach to consider is the replacement of legacy proprietary access credentials to portals or for how digital identity necessary to access consumer facing APIs could be done on some manner of renewal basis or upon sign up of new patient users of either portals or consumer facing APIs to leverage any new standards-based digital identity approach. This may be offered as a choice at first to patients who could still have the option of maintaining current access credentials. This kind of offering of access was a part of earlier Meaningful Use and Promoting Interoperability approaches for consumer access to portals.

The above approach would place requirements on App developers and HIT developers to follow suit to support standards-based digital identity and to start to move away from proprietary schemes that do not support the use of digital identity for consumer access beyond the boundaries of their own products. It seems a coordinated effort to support the acceptability of such credentials that follow the individual and are recognized for their ability to meet the bar set by federally recognized or industry recognized consensus-based standards is needed to make headway for their use.

a. What would providers need help with to accelerate the transition to a single set of trusted digital identity credentials for the patient to keep track of, instead of one for each provider?

To drive HIT developers to support the use of standards to support IAL2 identity assurance processes, support for the collection of additional identity information could be made part of certification requirements for demographic data collection and/or security. ASTP/ONC could reasonably expand certification criteria to address IAL2 identity assurance as well as AAL2 authentication requirements to support the use of digital identity credentials for patients and caregivers that are standards-based. These requirements could be connected to the Base EHR to drive their adoption into certified HIT required for use to participate in Promoting Interoperability where the program has impact for hospitals and eligible clinicians. Such credentials could then be portable and interoperable for use across other care settings for the same individual and accepted for use even if issued from another source. At the same time, CMS and ASTP/ONC could support or advocate for the accreditation or certification of IdPs to ensure common standards for portable interoperable digital identity credentials, ensuring policy equivalence.

b. How might CMS balance patient privacy with convenience and access to digital health products and services that may lead to significant improvements in health?

CMS can work with ASTP/ONC to support the development of certification criteria that would apply to the use of digital identity credentials that are portable and interoperable. CMS should work with OCR to provide guidance on the role that providers could play in the issuance of credentials that would leverage a hardened potentially independently certified version of the demographic data collection and registration processes providers already do.

CMS and OCR should promote or incentivize the use of industry best practice self-regulation for consumer facing digital health products that are independently used by patients and caregivers such as the CARIN Alliance Code of Conduct as we have seen no indication that there will be developments in the federal regulatory space to adequately address such requirements. In any event, the issuers of digital identity credentials and the processes that are used to accept them need to be independently evaluated either in certification or by requiring certification or accreditation or a combination.

PR-10. Regarding digital identity credentials (for example, CLEAR, Login.gov, ID.me, other NIST 800-63-3 IAL2/AAL2 CSPs):

a. What are the challenges and benefits for providers?

Many providers already are asked to use digital identity credentials for purposes such as electronic prescribing of controlled substances. However, the same individual might possess more than one set of these credentials should they work across multiple care settings under distinct individual or institutional settings. The challenge for providers is similar to that for patients when it comes to the need for having portable interoperable digital identity credentials that could be acceptable across care settings and entities. At a minimum, they face independent registration and identity proofing processes for each context where they may be given such a credential. The challenge also is that current requirements within both HIPAA Security (including as proposed in the recent HIPAA Cybersecurity Rule for Multi-Factor Authentication) is that all such requirements operate only within a covered entity and do not address the portability and interoperability of identity across entities. They do not set the stage for digital identity to follow the individual.

The benefits could come from having a portable interoperable credential that could cross contexts, jurisdictions, and what are currently distinct identity proofing requirements. We stated in prior response the desirability of establishing certification requirements to support the concept of a portable and interoperable digital identity and point CMS back to those remarks as they can apply to provider identity.

b. How would requiring their use improve access to health information?

Their use would support a trusted digital identity for the individual provider/clinician in access to health information. Additionally, it could support a hardened representation of identity for the purpose of trusted identity and trace-ability of identity within the medical record. This would enhance the reliability of author/individual identity for provenance, for assurance of individuals acting within their scope of practice, and for reliability and trust in the chain of custody for medical records. It also may serve to support downstream needs reliant on that trusted identity where the veracity and trust are significant such as for the sharing of EHI with external entities where authorship and trace-ability of source are significant such as for payment audit, fraud and abuse prevention, and medical review.

c. What are the potential downsides?

In the current environment, both regulatory requirements such as HIPAA Security, and HIT certification criteria presume that the requirements apply within a context - the provider as covered entity or care setting within which the identity holds meaning. There are practical significant legal and regulatory barriers to be overcome to support a portable interoperable digital identity based upon an identity that follows the individual, and that

could be accepted for use across contexts. In the meantime, maintenance of digital identities, and their context of use such as for controlled substance electronic prescribing or for addressing secure messaging within a given provider context or network through open and interoperable accessed provider directories is a desirable next best goal.

d. What impact would mandatory credentials have on a nationwide provider directory?

Mandatory credentials and requisite updates for providers and organizations would have a significant impact on the quality of information collected in a provider directory. Directories can benefit from verified attributes captured as part of identity assurance processes for individuals. However, FHIR endpoints and many Direct addresses are associated with organizations. In order for organizational identity proofing to be utilized to harden the quality of a provider directory, we need to tie into existing processes for identity assurance within the enterprise itself.

As an illustrative example, DirectTrust accredited HISPs and Registration Authorities identity assure both providers and organizations in the processes that are used to issue Direct addresses. When our members use the verified attributes collected in the process of issuing those certificates, the quality of directory entries is extremely high. This is not universal in our community.

The steps taken by the Registration Authority to assure the identity of an organization include the following:

- Perform individual identity assurance of a purported organizational representative
- Ensure the organization exists as a legal entity
- Validate that the representative works there
- Establish that the individual has access to and control over the domain where the certificate will be installed

When medium assurance certificates are issued for any purpose, both individual identity assurance (for the organizational representative) and organizational identity assurance is conducted. The advantage of using digital certificates as a source of truth is that if organizational changes take place, new certificates are almost always issued. When a health system rebrands or is acquired, it is likely that the domain name of the organization will change, forcing certificates that reference the old domain to change as a consequence. We see this regularly for Direct certificates, and the organizational attributes propagate to our directory as well.

Copyright 2025 by DirectTrust, All Rights Reserved | 1629 K Street NW, Suite 300 | Washington, DC 20006 | DirectTrust.org |

The same might be true for the domains associated with FHIR endpoints. For facilitated FHIR, these endpoints will have certificates that are issued by the DirectTrust community of Certificate Authorities. Therefore, the organizational identity assurance that is conducted for the issuance of these certificates could be used to populate a directory with verified attributes for the organization.

e. How could digital identity implementation improve provider data flow?

As discussed in previous responses, it would help to improve the reliability, veracity, and trustworthiness of provider identity in EHI significant to provenance and trace-ability for all the purposes of medical record integrity and downstream reliance that depends on an immutable identity of author and participation in medical record provenance.

f. Would combining FHIR addresses and identity improve data flow?

As stated above, organizational identity assurance attributes are associated with FHIR endpoint uniform resource identifiers (URIs), but these don't come from the individual identity assurance effort. DirectTrust, as the organization responsible for overseeing the issuance of FHIR certificates for facilitated FHIR, is in an excellent position to play a role in capturing these verified attributes for a directory. FHIR addresses are organizationally aligned, so the verified attributes collected about providers and clinicians would not include the organizational endpoints. In fact, providers may likely have multiple organizational connections. Individual attributes should include organizational alignment, but the information about organizations, their endpoint addresses, and the identity assurance of those organizations could be facilitated with a verifiable process like certificate issuance.

PR-11. How could members of trust communities (for example, QHINs, participants and sub participants in TEFCA, which requires Identity Assurance Level 2 (IAL2) via Credential Service Providers (CSPs)) better support the goals of reduced provider and patient burden while also enhancing identity management and security?

Reducing burden while enhancing identity management and security can be the outcome of moving to credential portability and reciprocity and ubiquitous use of credentials throughout the ecosystem and for multiple workflows. Patients will experience a more coherent workflow for intake and for gaining access to health records from multiple sources. Provider organizations will reduce HIM costs associated with duplicate records and release of information with more health records successfully retrieved electronically directly by the patient. Provider burden with resolving patient matching issues with

queried results will be reduced. If provider organizations embrace common credentials as a mechanism to allow for providers to have single sign-on capabilities to enterprise systems, they will only have one credential to manage, and if reciprocity is established for workforce credentials, the same credential could be used at multiple healthcare organizations.

Security is enhanced by allowing for a single, strong credential to function in all contexts that can be revoked if it is compromised.

Transitioning to facilitated FHIR communication will ensure that data holders will know reliably who is asking for data. Facilitated FHIR does not traverse the QHIN gateways and instead goes directly from endpoints served by one QHIN to those served by another, both of which have been identity assured. For our part, DirectTrust supports accreditation of the Certificate Authorities to ensure that trustworthy processes are followed in the certificate issuance process. DirectTrust currently issues certificates for Carequality, eHealth Exchange and TEFCA gateways, and now is offering certificates for Facilitated FHIR under TEFCA.

D. Payers

PA-3. How can CMS encourage payers to accept digital identity credentials (for example, CLEAR, ID.me, Login.gov) from patients and their partners instead of proprietary logins?

See responses to PC-14 and PR-9. Similarly, CMS could assert contractual requirements or requirements associated with payers administering federal health programs or that use federal funds including Medicaid, CHIP, Medicare Advantage, and federally funded health insurance marketplaces to require the use of standards-based digital identity credential registration processes and credentials. This kind of precedence has been established by CMS-9115-F and CMS-0057-F including for requirements to utilize the FHIR standard for registration, authorization, and authentication of apps involved in accessing payer held EHI.

PA-4. What would be the value to payers of a nationwide provider directory that included FHIR end points and used digital identity credentials?

Under CMS-9115-F, impacted payers are already required to make available a publicly accessible provider directory through a FHIR API of the providers that are in their network(s). This requirement includes the provision of provider names, addresses, phone numbers, and specialties. Similarly, under that same regulation, providers are to supply their digital contact information to the National Provider and Plan Enumeration System

(NPPES) including FHIR endpoints, RESTful endpoints, Direct addresses and similar digital contact information. These are both examples of essential information contributed by stakeholders that are not authoritative for the data they supply.

As elucidated above in TD-5, a multi-contributor directory that collects data from several constituencies which are each authoritative for the data they contribute, reliable identifiers will need to be utilized to ensure that appropriate associations can be made between the contributions. For providers and provider organizations, type 1 and type 2 NPI will work reasonably well, but there are gaps for the health plans and insurance companies as no standardized identifier standard has been adopted. This will place the onus on payer contributors to accurately select the type 2 NPI or EIN or both for provider organizations they reference in their information. While payer endpoints have URIs that could be published for access to API information, looking up these organizations using only organizational demographics will be a challenge in practice for users of a directory seeking payer information. While both the NPPES ESI and the Health Plan Identifier technically exist, according to the CMS website, there is no longer an adopted standard for the identification of health plans. If a digital certificate could be issued to the health plan endpoints at appropriate identity assurance, verified attributes including EIN could be captured and contributed to a national directory. This would allow for the disambiguation and reliable discovery of health plan endpoints by providers and consumers. As discussed, it also provides a mechanism to force the update of such entries when organizational changes take place.

E. Technology Vendors, Data Providers, and Networks

2. Digital Identity

TD-3. Regarding digital identity implementation:

a. What are the challenges and benefits?

As discussed in response to PC14 and PR9, there is much to overcome with the current use by HIT developers of proprietary credentials, and non-standard identity credential registration and issuance processes. Proprietary means of identity management, and authentication of patient and provider users have become entrenched within developer specific products and even unique between implementers of the same developer products across deployments.

b. How would requiring digital identity credentials (for example, CLEAR, Login.gov, ID.me, other NIST 800-63-3 IAL2/AAL2 CSPs) impact cybersecurity and data exchange?

We point back to our responses to PC-14 for the impacts on use by patients, to PR-9 for the impacts on use by providers, and to PA-4 for payers for data exchange. In terms of cybersecurity, the adoption of digital identity credentials that are portable or at least interoperable will disrupt the use of proprietary digital identity methods, and in the long run pave the way for trusted identity in an interoperable way to support provenance of the individual in roles such as requestor or author of EHI in health information exchange. It should also support a more reliable basis for trusted identity in authentication processes for both individuals and organizations significant to supporting trust in health information exchange such as is required by TEFCA. Credential theft and phishing attacks are the most significant cause of breach, in particular for workforce members with high-privilege accounts. If AAL2 requirements were a part of minimum requirements for such credentials a great many catastrophic events over the past several years could have been averted.

c. What impact would mandatory use of the OpenID Connect identity protocol have?

It should work to promote the standardization of digital identity credentials, and pave the way for broader adoption of FHIR APIs for use in health information exchange. It also should support the development of digital health products that leverage the FHIR standard for access to EHI from sources external to the user context to allow for use cases such as patients seeking to centralize their EHI to one source or to support developers seeking to leverage external data sources to be better supported. It also may pave the way to at least interoperable digital identity. OpenID Connect on its own isn't enough to solve the digital identity needs of an interoperable future, but it provides the necessary foundation to allow for the secure communication of signed attributes from client to server and other important features.

3. Technical Standards and Certification

TD-4. How can CMS better encourage use of open, standards-based, publicly available APIs over proprietary APIs?

CMS should emphasize the benefits of using standards-based APIs that support the use of interoperable digital identity versus the use of proprietary digital identity as a means of promoting the benefits of easing health information exchange. CMS and ASTP/ONC can use various regulatory levers such as HIT certification, the Base EHR concept, and

prerequisite requirements for the use of Certified EHR Technology to drive adoption of standards-based APIs where those requirements hold impact. CMS should also make clear its adoption of standards-based APIs to make available the EHI held by Medicare, and by the types of health plans it oversees by making available a directory of FHIR endpoints used to comply with CMS-0057-F as a lead example for promoting the use of standards-based APIs.

However, as we state in PR-7, we also believe that the pathway for utilizing proprietary APIs and for using yet to be mandated FHIR API capabilities should be enabled by requiring these APIs be publicly documented and that a reasonable and open economic model for utilizing them should be established. Certification or other incentive approaches could be taken to provide this encouragement. We can expect a mixed market for some time unless there are another round of incentives to fund the move from proprietary to standards-based, which we don't expect is likely.

TD-5. How could a nationwide provider directory of FHIR endpoints improve access to health information for patients, providers, and payers?

CMS has long wanted to deploy a directory that could be used for all constituencies as a single source of truth, particularly for identifying endpoints for making interoperability connections. DirectTrust responded to the 2022 NDH Directory RFI and would like to contribute to any CMS directory effort as it moves forward.

As we stated in PR-10d, we believe that identity assurance can provide verified attributes to populate directories for both individuals and organizations. The most robust identity assurance that is taking place in the ecosystem is in support of the issuance of digital certificates for endpoints, websites and otherwise. As shared above, Direct Secure Messaging, our PKI based exchange network requires that both organizational and individual identity assurance are maintained. Some contributors to the DirectTrust directory place only verified attributes in directory entries. This is best practice.

In 2023, we completed a substantial upgrade of our directory to comply with the basics of the FAST National Directory of Healthcare Providers & Services (NDH) Implementation Guide. Our directory supports contributions of CSV files but allows for distribution of the aggregated directory using either CSVs or NDJASON files that express our directory in terms of the appropriate FHIR resources. We don't align with the full NDH IG as doing so wouldn't have a value to us, but we assumed that if CMS deployed a directory conformant with the guide that we could easily contribute Direct addresses to it without rearchitecting.

The challenge with the tiered, multi-contributor directory that is contemplated by CMS is that maintaining a reliable and updated directory will require numerous constituencies to engage. If you think of a provider directory as a layer cake, each layer comes from different constituencies, each authoritative for the data in their layer. If one constituency is responsible for providing the attributes for another constituency, this has proven to be a failure as in the example of asking providers (the individuals) to update their digital contact information or payers to maintain addresses and phone numbers of provider organizations. Direct addresses and FHIR endpoints would ideally come from the networks (DirectTrust, TEFCA and others). DirectTrust made a change to our policy to explicitly allow us to collaborate with CMS so we could provide Direct addresses (at least for those addresses published with NPIs).

In order for the layer cake to work from top to bottom, shared identifiers are needed as foreign keys so one layer can understand the next. With providers and provider organizations, the type 1 and type 2 NPI numbers can play this role, though a better model for entities that supports a complex hierarchy and isn't limited to only healthcare would probably be better. We like GLEIF for this purpose, but this would probably be a substantial scope enhancement for a CMS national directory effort.

We presume that CMS will be reviewing the NDH IG for this new CMS directory work, but the model that the IG proposed was based upon an "attestation" that assumed organizations authoritative for data would validate prior to submission. Promoting an identity assurance process and a mechanism for organizations to ensure that verified attributes are obtained and maintained over time is a step forward.

We hope to be involved in the directory discussion with CMS as it continues. Success will depend upon a plan that is robust and complete, with an initial scope that is limited and can be accomplished in a year or two. However, if the plan doesn't contemplate a comprehensive end state, the initial scope may be unusable.

Who should publish such a directory, and should users bear a cost?

In our experience managing and maintaining the DirectTrust Aggregated Directory of around one million entries for our own purposes, we charge Network Services Fees to the accredited member operators of our network for directory services and trust services. Since we offer the Directory to our members under the terms of our policies, we are able to maintain standards for policy conformance. Directory services, while costly to maintain are seen as essential as included features of network operations. End users are not likely to expect that access to a directory will cost them anything, but for participants in

networks, directories can easily be seen as an included feature without a separate line-item cost. Charging for network access to network participants as part of overall network services is the typical approach in the exchange network community.

CMS could certainly publish the directory, and could charge networks, payers and provider organizations a subscription to use it, but any fee would impact adoption. This would be equally true if an external party were to operate the directory. The advantage of making it a network asset would be that networks could embed the cost of the directory in the prices they charge participants and reliance on the directory asset would be in lieu of a directory they maintain for themselves.

An architecture that assumes contributors only have responsibility for their own layer but have access to an aggregation of all the layers makes the value of the whole far greater than what the individual organization contributes. At the recent Listening Session, the domain naming service (DNS) metaphor was used which suggests a distributed, decentralized model which operates as though it were monolithic.

TD-6. What unique interoperability functions does TEFCA perform?

a. What existing alternatives should be considered? b. Are there redundant standards, protocols or channels or both that should be consolidated?

We first point back to our response to PR-6 and apply that to respond to this question. The most significant task for CMS and ASTP/ONC is to focus on how TEFCA can complement existing health information exchange for the purposes of use beyond those currently mandatory as we discuss in response to TD-6. We propose that the Common Agreement, or the QHIN Technical Framework allow Direct Secure Messaging as a parallel path for push-based exchange in much the same way as the eHealth Exchange DURSA and the Carequality Connected Agreement make this allowance explicitly for electronic case reporting (eCR). This would have the impact of reducing overall cost and demonstrating TEFCA adoption by incorporating Direct Secure Messaging scale as a part of TEFCA exchange.

TD-8. What are the most effective certification criteria and standards under the ONC Health IT Certification Program?

In general, the most effective of the certification criteria and standards are those that support the adoption of interoperability standards where they have broad benefit and drive out proprietary means of what should be standard. The Direct Standard® provides a

low cost and easy to deploy mechanism for push interoperability that should continue to be required. Others include electronic prescribing standards that support workflow, drive incorporation of EHI to support following the patient to present a whole view of needed clinical information such as for a reconciled medication list, and that bring EHI to the point of need.

TD-9. Regarding certification of health IT:

a. What are the benefits of redefining certification to prioritize API-enabled capabilities over software functionality?

This would hold the potential for improving the availability of EHI for both providers, patients, and other stakeholders in actionable ways at the point of need if it also included an expansion of requirements to enable add, and modify types of capabilities to support making the EHI available within workflow, and to support consolidation of EHI to support the use case at hand such as reconciliation of EHI for specific needs, or for communicating updates in statuses of key work activities like prior authorization decisions.

b. What would be the drawbacks?

The current use of the FHIR standard has been mostly limited to support query. The USCDI and FHIR resources provide the data structures necessary for that, but without defining transactions and workflows required for certification, it is possible developers would have too much latitude and little clarity about what capabilities need to be supported. The workflow gap present in some of the current certification criteria has created usability issues for interoperability workflows. For example, stipulating the data for administrative transactions like patient intake without providing guidance about what transactions and workflow are required might not cause developers to finish the job.

4. Data Exchange

TD-12. Should CMS endorse non-CMS data sources and networks, and if so, what criteria or metrics should CMS consider?

CMS should consider making available directories of information for payers impacted under CMS-9115-F and CMS-0057-F and make available FHIR endpoints for enabling access to payer held EHI for patients and their providers.

TD-13. What new opportunities and advancements could emerge with APIs providing access to the entirety of a patient's electronic health information (EHI)?

CMS and ASTP/ONC should seriously consider developing a different way of presenting the USCDI as the required set of EHI to be enabled for health information exchange using both FHIR API and C-CDA interoperability or for enabling patient access to their EHI. We recommend the development of a common minimum set of the USCDI version (and attendant FHIR resources when applicable) in effect as a certification standard (currently v3) be identified that all HIT seeking certification to any criterion that involves the use of the USCDI as a certification standard be able to exchange. Beyond this, we recommend identifying as optional additional data types and supporting FHIR resources as applicable to the criterion that are appropriate to the intended scope and purpose of the HIT being presented for certification especially when the HIT is intended for use by specialty providers or mid-level clinicians who do not interact with the full scope of the USCDI version in effect as a certification standard. ASTP/ONC might consider making those additional "optional" data types and classes required if a developer is presenting HIT for use in general acute care settings or in primary care specialties if that helps make for distinction for when the full scope of the USCDI is appropriate to a given type of HIT.

This kind of approach could also be useful for creating models for optional certification for "USCDI +" data sets that are tailored to fit specific use cases.

a. What are the primary obstacles to this?

Please see our comments on the USCDI discussed in response to drawbacks question under TD-9.

b. What are the primary tradeoffs between USCDI and full EHI, especially given more flexible data processing capabilities today?

The primary tradeoff is that not all of the EHI that might fit broader definitions such as the full expression of the Designated Record Set (DRS) under HIPAA and the Information Blocking regulations may be enabled for exchange by certain types of HIT. However, there needs to be a better fitness of the certification requirement to match the intended scope and use of specialty HIT or for more reduced scope and function of HIT presented for certification but not currently able to certify without unnecessary throwaway development of capabilities of little to no use to their provider clients.

TD-14. Regarding networks' use of FHIR APIs:

a. How many endpoints is your network connected to for patient data sharing? What types, categories, geographies of endpoints do you cover? Are they searchable by National Provider Identifier (NPI) or organizational ID?

DirectTrust is not a data holder. Our only use of FHIR APIs is the DirectTrust Aggregated Directory and the ability for a Direct message to carry a FHIR payload.

b. How are these connections established (for example, FHIR (g)(10) endpoints, TEFCA/Integrating the Health Enterprise (IHE) XCA, or proprietary APIs)?

The DirectTrust Aggregated Directory is a critical enabler of trusted, secure health information exchange through Direct Secure Messaging. By providing a centralized, validated source of more than one million identity-assured Direct addresses, the Aggregated Directory powers the scalability and reliability of interoperable communication across the healthcare ecosystem.

Users can find trusted Direct addresses from thousands of organizations, departments/teams, and individuals without needing to query multiple directories individually. This is also searchable by NPI. Direct addresses are identity-verified, ensuring high confidence in locating the proper endpoint for secure information exchange.

Organizations can integrate the DirectTrust Aggregated Directory into their systems to automate workflows (e.g., referral routing), reduce administrative burden, and support more seamless care coordination. DirectTrust's FHIR-based Directory combines individual contributions into our comprehensive Aggregated Directory. HISPs who contribute to the Directory receive access to the Aggregated Directory in return. They are required to refresh their Aggregated Directory information from DirectTrust every 72 hours to ensure their clients have access to current information. Organizations integrate data from or query the Aggregated Directory to discover Direct addresses needed for trusted communication.

DirectTrust recently completed a multi-year Directory Improvement Initiative that included technology, policy, and education initiatives. As a result, Directory participation and information quality has increased, alongside technology that's more standardized and easier to access. The Directory was rearchitected to increase responsiveness and scalability, deploy an API for access and update, and allow for a secondary means of Directory search. Directory participation is now required as part of HISP accreditation (unless a valid exemption applies), along with certain requirements for upload and

download timeframes for changes. Clinical organizations that access the Directory now must publish at least one address (can be Department/Team address).

Future Vision:
DirectTrust is committed to continuously improving the Aggregated Directory by: Improving Aggregated Directory data quality and completeness. Enhancing searchability by leveraging FHIR-based API access that rapidly offers new and innovative options for using Directory information. Facilitating cross-network directory discovery initiatives to map other endpoints (e.g., FHIR endpoints, Home Community ID endpoints for XCDR) to associated Direct addresses. A public-private partnership between DirectTrust, HL7 (National Directory standard), The Sequoia Project (TEFCA/FHIR Directory), and CMS would dramatically advance interoperable exchange.

TD-16. What are the tradeoffs of maintaining point-to-point models vs. shared network infrastructure?

Point-to-point models and shared network infrastructure can and do coexist in the market and for good reasons. Individually orchestrated standards-based or proprietary point-to-point models of exchange are most often servicing existing needs for local health information exchange where they have been seen as necessary by the participating exchange partners. This may be because of contractual, closed model circumstance (for example, for an ACO or a health system exchanging with its constituent members, or reference laboratory interfaces). The parties may wish to keep this connection in place even if standard based communications by networks may be possible. Shared network infrastructure of functioning HIEs could replace specific exchange solutions, if they better support the exchange purpose. They also can replace point-to-point models that use proprietary specifications limited to their ability to be reused or maintained where standards are available for lower cost broader scale exchange. However, the cost of replacing existing connections that are functioning adequately for the purpose may be dollars misspent.

a. Do current rules encourage scalable network participation?

Regulation has an impact on network participation as do the obligations of participation within a trust community. The encouragement provided by Promoting Interoperability and the Information Blocking Rule do have an impact on participation in the networks. However, amongst the largest vendors, competitive pressure has had as much impact as regulation.

Customers and the general public have begun to have an expectation that vendors would invest in interoperability capabilities and participate in interoperability initiatives. This does not have the same impact on the participation of the vendors with relatively low market share. For some use cases, participation is driven by customer requirements and business value and this sometimes even drives the smallest players to participate. The desire to receive referrals from the health system has organically attracted many long term post-acute players to the DirectTrust network.

Exchange of clinical EHI for treatment or for other permitted disclosure purposes both as permissible under HIPAA, and as practiced in many local, regional, or national exchanges may require response for participants who agree to the terms of participation to share information with each other, but participation is encouraged not required. This may be compelling but still voluntary. Exchange of EHI in support of closed contexts (a state mandated HIE, a contractually required exchange to support a value-based care model, etc) may be required by law or by contractual obligation for the limited purposes and scope of that limited context.

b. What changes would improve alignment (for example, API unification, reciprocal access)?

Alignment may be driven by contractual requirements, local/regional/state law, or the program requirements for specific types of exchange purposes where the accrediting or regulating entity dictates participation. It is more likely that improved incentives or business drivers for use of voluntary participation is a more effective driver. Further, and specific to the case of TEFCA as discussed in earlier comments to this RFI, defining the complement that shared network infrastructure can provide to establish more local or point-to-point exchanges may be effective to encourage participation in the right context such as using TEFCA for sub-purposes of payment like healthcare attachments or provision of EHI for non-HIPAA mandated transaction types. The value proposition must be demonstrated for participants to consider investing resources to implement. Incentive payments or reimbursement improvements alone do not always drive the value case where the limited time and talent of resources to execute implementation may be a more significant factor than the funds that might be returned for the effort.

TD-17. Given operational costs, what role should CMS or ASTP/ONC or both have in ensuring viability of healthcare data sharing networks, including enough supply and demand, that results in usage and outcomes?

The best mechanisms that achieve adoption take advantage of existing business realities and improve business conditions by enabling capabilities of value for commercial entities. For example, in the DirectTrust ecosystem, we see interest and solid growth in sending referrals electronically. This use case is an example of aligned incentives - referrals across business boundaries are common and the manual and non-standards-based approaches are more expensive for both sender and receiver. We are seeing communities working together to make this model work to improve business conditions and patient care.

Also, if we can remove some of the barriers (digital identity and directories) we have discussed in our RFI response, the companies that seek to aggregate a patient's records under a variety of business models may finally experience solid growth. Providing incentives in payment models as well as tightening enforcement of existing legislation with a focus on enabling these new players should continue.

Value-based care models provide natural incentives for gaining access to the longitudinal records necessary to see the whole person for an organization's patients. Once the majority of payments for care are for quality rather than quantity, economic incentives should align with the goal of ubiquitous information exchange. To incentivize providers not eligible for the Promoting Interoperability programs, CMS must also consider incorporating standards for states via Medicaid Technology Funding, in innovation models, in outpatient and ambulatory surgery centers, and in home health, hospice, and long-term care. Continuing to encourage and to create value-based care approaches may have more impact on interoperability than explicit requirements for information exchange.

If the government believes as we do that standards-based approaches promote competitiveness, and are the least costly, highest value approach, then there should continue to be incentives for implementing and adopting standards rather than proprietary or monolithic platform approaches. Ensuring standards are adopted can help reduce consolidative pressures on covered entities and business associates, helping to control costs and improve the care for all patients.

F. Value-Based Care Organizations

1. Digital Health Adoption

VB-3. What are essential health IT capabilities for value-based care arrangements?
a. Examples (not comprehensive) may include: care planning, patient event notification, data extraction/normalization, quality performance measurement, access to claims data,

attribution and patient ID matching, remote device interoperability, or other patient empowerment tools.

Critical functionalities for value-based care arrangements include:

- Person-centered care planning including all necessary structures to describe a comprehensive person-centered care plan
- Person centered care management including sharing of care plan information, updates, status changes, and necessary clinical documentation capabilities
- Patient and Caregiver engagement capabilities including patient portals, APIs, and information accessibility at the level of the value-based care arrangement for the patient and caregiver to have access to the level of the shared care arrangement for all EHI produced by the value-based arrangement
- Closed loop referral management including for communication of clinical orders, diagnostic test results, specialist clinical reports, image reports, referral summaries and similar information
- Appointment and provider/resource scheduling across the scope of the value-based care arrangement including patient/caregiver access to appointment schedules and provider appointment availability
- Standards-based clinical information sharing across the scope of the value-based care arrangement between participating providers
- Clinical quality measurement capabilities including data abstraction, data compilation, measure calculation, measure reporting (as required), and operational dashboards of quality measures
- Risk stratification and population based risk profiling capabilities

b. What other health IT capabilities have proven valuable to succeeding in value-based care arrangements?

- Beneficiary/patient consent support for participation in the value-based care model
- Beneficiary allocation or enrollment capabilities for patients identified to the value-based care arrangement
- Sharing of beneficiary information, claims history, and quality measurement performance data for the value-based care model
- Risk scoring and risk management capabilities to support beneficiary risk scoring and management

3. Technical Standards

VB-14. How could implementing digital identity credentials improve value-based care delivery and outcomes?

Depending upon the methodologies employed for the support and management of digital identity credentials, the following options may be feasible:

- Facilitate a value-based arrangement wherein all participants, including individual clinicians and users, utilize a shared standards-based Identity Provider (IdP).
- Enable the value-based arrangement to serve as, or delegate to, a common entity, all registration and identity proofing functionalities required to service the participants of the arrangement.
- Establish a trust community comprising the participants of the value-based arrangement.
- Institute a shared framework for digital identity to underpin health information exchange, ensure provenance of individual identity within Electronic Health Information (EHI) exchanged within the value-based arrangement, and establish identity trust therein.
- Deploy a single sign-on and digital identity mechanism to enable access to any Health Information Technology (HIT) implemented within the value-based arrangement for burden reduction.

VB-15. How could a nationwide provider directory of FHIR endpoints help improve access to patient data and understanding of claims data sources? What key data elements would be necessary in a nationwide FHIR endpoints directory to maximize its effectiveness?

Please see prior comments on the adoption of a nationwide provider directory responded to in the Payer and Provider stakeholder sections above.

Not Addressed in the RFI

We applaud the RFI's substantial breadth of subject matter. However, we noted an absence of questions directed toward privacy and security, outside of its relationship to digital identity. We will encourage CMS and ASTP/ONC to work closely with the referenced organizations and vendor-neutral collaborative efforts to enhance the posture of all stakeholders named in this RFI.

Given that the HHS Office for Civil Rights data breach web portal shows 725 data breaches of 500 or more records in 2024, the third consecutive year that more than 700 large data breaches have been reported to OCR. Hacking and IT incidents accounted for the majority of breached records, with at least 275 million healthcare records exposed across those incidents, the threat

only continues to increase. In response, DirectTrust has launched a Cybersecurity Workgroup by which its members seek to provide actionable and attainable best practices with support from a wide range of industry standards. The Workgroup is considerate of the needs of all, including smaller and disenfranchised communities, seeking cost effective implementation and adoption options, and supports advocacy across industry and governmental bodies, advancing capabilities needed for a secure, trusted, interoperable digital ecosystem, including by addressing under-resourced participants.

DirectTrust's key policy recommendations are as follows:

- **Comprehensive Cybersecurity Support**. DirectTrust advocates for accreditation, mechanisms enabling financial support for training and workforce development, technical incentives, and policy harmonization to strengthen healthcare cybersecurity.
- **Incentives & Assistance**. Government-backed grants, cost-effective security solutions, tax credits, and shared security resources featuring practical tips and "how-to" documents such as those provided by CISA (Cybersecurity & Infrastructure Security Agency) and HHS 405d can help under-resourced organizations to adopt best practices.
- **Quantum-Resistant Security**. Proactive investment and federal guidance are essential for transitioning to post-quantum cryptographic solutions in healthcare.
- **Interoperable Identity Standards**. Aligning with frameworks like NIST Digital Identity Guidelines and DirectTrust's identity verification standards to create a unified, trusted approach.
- **Regulatory Alignment**. Harmonizing federal and state regulations—such as HIPAA, FTC (Federal Trade Commission) rules, and state laws— this can reduce compliance burdens and foster secure information exchange.
- **Recognize Independent 3rd Party Accreditation**. Elevate the use of accreditation to validate adequate cybersecurity practices. Having a recognized seal provides assurance that an organization follows the most current standards. This also reduces the burden on health and social care organizations from completing tedious oversight on their partners or Business Associates and having the skilled workforce with which to do that review. Healthcare organizations that are accredited are more likely to gain trust from patients, providers, and partners.

DirectTrust also leads, or participates in, other national workgroups addressing privacy and security to advance the posture of the entire healthcare ecosystem. We recommend that HHS incorporate the work of these organizations to the extent possible within policy. These include:

- The Health Sector Coordinating Council (HSCC)[3]. This organization has also recently released valuable data on the state of resource constrained healthcare providers and cybersecurity.[4]
- Sequoia Project Interoperability Matters Privacy & Consent Workgroup[5]
- WEDI Privacy & Security Workgroup[6]

Within the Accreditation arm of DirectTrust our programs assess unique criteria that relate to secure interoperable exchange with data sources when health applications are connected to data sources either directly or through national networks including:

- Criteria to assess compliance with the CARIN Code of Conduct for EHI data use transparency outside the HIPAA boundary.
- Criteria to evaluate interoperability and test compliance with HL7 Security for Scalable Registration, Authentication and Authorization FHIR Implementation Guide demonstrating secure interoperable exchange with data sources when health applications are connected to data sources either directly or through national networks.
- Criteria to demonstrate compliance with efficacy, data privacy and security requirements for digital therapeutics applications and platforms (DTx).
- Criteria and programs that evaluate an organization's attention to identity and credential management.

Conclusion

We appreciate your consideration of our feedback and recommendations.

Sincerely,

Scott Stuewe

Scott Stuewe
President and CEO, DirectTrust

[3] https://healthsectorcouncil.org/
[4] https://healthsectorcouncil.org/on-the-edge-cybersecurity-health-of-americas-resource-constrained-health-providers/
[5] https://sequoiaproject.org/interoperability-matters/privacy-and-consent-workgroup/
[6] https://www.wedi.org/workgroup-community/privacy-and-security/